Отчет по результатам тестирования на проникновение инфраструктуры компании

Заказчик: ACME Inc.

Исполнитель: Буртасов А.О.

Шаг 1.

Краткое описание проведенного анализа

ws01 (10.0.20.11) – рабочая станция. Видны стандартные порты Windows (SMB, RDP). Но самое интересное – открыты порты 5985/5986 (WinRM). Если злоумышленник найдет учетные данные, он сможет удаленно выполнять команды через PowerShell.

dc01 (10.0.20.51) – контроллер домена acme.skb. Открыт весь набор портов Active Directory (LDAP, Kerberos, DNS, Global Catalog). Также есть WinRM и RDP.

webserver02 (10.0.20.60) – веб-сервер. На нем работает WordPress 5.3 (устаревшая, а следовательно, уязвимая версия). В заголовке страницы Nmap расшифровал название компании: "ООО Софтвер Солюшинз".

webserver01 (10.0.20.61) – веб-сервер, на котором развернуто приложение DVWA (Damn Vulnerable Web Application. Более того, Nmap нашел открытый репозиторий .git в корне сайта. Также открыт порт MySQL (3306).

Все обнаруженные порты являются стандартными для своих сервисов, администраторы ничего не меняли –> проще атаковать.

Описание результатов сканирования:

Хост 1:

1. Имя хоста: ws01.acme.skb
2. IP: 10.0.20.11
3. ОС: Microsoft Windows 10 / Windows Server 2019 (Build 10.0.17763)
4. Открытые порты: 135/tcp, 139/tcp, 445/tcp, 3389/tcp, 5357/tcp, 5985/tcp, 5986/tcp. Все порты являются стандартными для своих сервисов.
5. ПО:
    - Microsoft Windows RPC (135)
    - Microsoft Windows netbios-ssn (139)
    - Microsoft SMB 3.1.1 (445)
    - Microsoft Terminal Services / RDP (3389)
    - Microsoft HTTPAPI httpd 2.0 (5357)
    - Microsoft WinRM / Windows Remote Management (5985, 5986)

Хост 2:

1. Имя хоста: dc01.acme.skb

2. IP: 10.0.20.51
3. ОС: Microsoft Windows Server 2019 (Контроллер домена)
4. Открытые порты: 53/tcp, 88/tcp, 135/tcp, 139/tcp, 389/tcp, 445/tcp, 464/tcp, 593/tcp, 636/tcp, 3268/tcp, 3269/tcp, 3389/tcp, 5357/tcp, 5985/tcp, 5986/tcp. Все порты являются стандартными для контроллера домена AD.
5. ПО:
    - Simple DNS Plus (53)
    - Microsoft Windows Kerberos (88)
    - Microsoft Windows RPC (135)
    - Microsoft Windows netbios-ssn (139)
    - Microsoft Windows Active Directory LDAP (Domain: acme.skb) (389, 636, 3268, 3269)
    - Microsoft SMB (445)
    - kpasswd5 (464)
    - Microsoft Windows RPC over HTTP 1.0 (593)
    - Microsoft Terminal Services / RDP (3389)
    - Microsoft WinRM (5985, 5986)

Хост 3:

1. Имя хоста: webserver02.acme.skb
2. IP: 10.0.20.60
3. ОС: Linux 5.X (Ubuntu/Debian)
4. Открытые порты: 22/tcp, 80/tcp. Порты стандартные.
5. ПО:
    - OpenSSH 8.2p1 Ubuntu (22)
    - Apache httpd 2.4.38 (Debian) (80)
    - WordPress 5.3 (обнаружен через http-generator)

Хост 4:

1. Имя хоста: webserver01.acme.skb
2. IP: 10.0.20.61
3. ОС: Linux 5.X (Ubuntu)
4. Открытые порты: 22/tcp, 80/tcp, 3306/tcp. Порты стандартные.
5. ПО:
    - OpenSSH 8.2p1 Ubuntu (22)
    - Apache httpd 2.4.41 (Ubuntu) (80)
    - MariaDB 10.3.38 (3306)
    - DVWA (Damn Vulnerable Web Application) – уязвимое веб-приложение.
    - Обнаружен открытый Git-репозиторий по адресу https://github.com/digininja/DVWA.git.

Шаг 2.

Краткое описание проведенного анализа.

На рабочей станции бухгалтера (ws01 / 10.0.20.11) открыты порты RDP (3389) и WinRM (5985/5986), а в открытом доступе найдены данные для входа.

Описание результатов изучения веб-сайта:

Локализация информации	**Найденная информация**
Главная страница (http://10.0.20.60/), раздел комментариев	1. Выявлены имена пользователей (сотрудников): Zinaida Rogova, Следак_в_законе. 2. Выявлен адрес электронной почты сотрудника: student@acme.skb. 3. Подтверждено использование CMS WordPress версии 5.3.
Страница авторизации WordPress	1. Обнаружена страница входа в административную панель CMS: http://10.0.20.60/wp-login.php. 2. Выявлен логин администратора сайта: admin (указан в поле Author в RSS-ленте).
Файл robots.txt (http://10.0.20.60/robots.txt)	1. Обнаружены учетные данные, предположительно, для главного бухгалтера (аббревиатура BUH), оставленные разработчиками в открытом виде: - Login: student - Password: PerfectionPersonified

Шаг 3.

Краткое описание проведенного анализа.

Выполнено автоматизированное сканирование инфраструктуры заказчика с помощью сканера уязвимостей OpenVAS. Сканирование позволило выявить ряд критических, средних и низких уязвимостей в конфигурации веб-серверов, операционных систем и сетевых служб.

Были обнаружены проблемы с передачей данных в открытом виде, устаревшими протоколами шифрования, а также риски раскрытия конфиденциальной информации через открытые директории и файлы.

Ниже приведен список обнаруженных уязвимостей и оценка потенциальных рисков.

Обнаруженные уязвимости:

ID уязвимости	Краткое описание	Уровень угрозы	Потенциальные риски
CVE-2021-43008	Уязвимость раскрытия информации в Adminer (версии 1.12.0 - 4.6.2)	High	Позволяет атакующему читать произвольные файлы на сервере, запрашивая подключение Adminer к удаленной БД MySQL.
phpinfo() output Reporting	Наличие доступного файла phpinfo() на веб-сервере	High	Раскрытие конфигурации сервера, версий ПО, путей и переменных окружения, что значительно облегчает поиск дальнейших векторов атаки.

CVE-2019-9978	Уязвимость XSS в плагине WordPress Social Warfare (< 3.5.3)	Medium	Уязвимость межсайтового скриптинга, позволяющая внедрять вредоносный контент на сайт и похищать сессии пользователей.
Sensitive File Disclosure (HTTP)	Доступ к чувствительным файлам по HTTP	Medium	Возможность доступа к конфигурационным файлам, логам или бэкапам, что может привести к утечке учетных данных и ключей.
Source Control Management (SCM) Files Accessible	Доступ к файлам системы контроля версий (Git)	Medium	Доступ к директории .git позволяет восстановить исходный код приложения и найти в нем захардкоженные пароли и секреты.
Cleartext Transmission of Sensitive Information	Передача чувствительной информации в открытом виде	Medium	Учетные данные передаются по незащищенному протоколу HTTP, что позволяет перехватить их с помощью MITM-атаки.

Missing 'HttpOnly' Cookie Attribute	Отсутствие атрибута HttpOnly у сессионных cookie	Medium	Позволяет получить доступ к cookie-файлам через JavaScript, что открывает путь к краже сессий (Session Hijacking).
DCE/RPC and MSRPC Services Enumeration	Перечисление служб DCE/RPC и MSRPC	Medium	Позволяет атакующему получить детальную информацию о хосте, запущенных службах и потенциальных векторах для эксплуатации.
SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protocol Detection	Использование устаревших протоколов TLS 1.0/1.1	Medium	Протоколы подвержены известным криптографическим уязвимостям (BEAST, FREAK), что ставит под угрозу конфиденциальность данных.
SSL/TLS: Certificate Signed Using A Weak Signature Algorithm	Сертификат подписан слабым алгоритмом (SHA-1)	Medium	Использование криптографически слабого алгоритма подписи снижает надежность SSL/TLS-защиты и вызывает предупреждения в браузерах.

TCP timestamps	Включены TCP timestamps	Low	Позволяет удаленно вычислить время непрерывной работы хоста (uptime).
ICMP Timestamp Reply Information Disclosure	Раскрытие информации через ICMP Timestamp	Low	Ответ на ICMP-запрос временной метки теоретически может быть использован для эксплуатации слабых генераторов случайных чисел.

(Примечание: в отчете также фигурируют старые CVE от Microsoft (например, CVE-2010-0020), но со статусом Closed, что означает, что эти уязвимости уже пропатчены и не представляют угрозы, поэтому в таблицу активных рисков мы их не включаем).

Шаг 4.

Краткое описание проведенного анализа.

_____

Описание обнаруженной конфиденциальной информации:

Название файла	**Найденная информация**
dump.sql (webserver02, 10.0.20.60)	Дамп базы данных MySQL WordPress. Содержит хэши паролей пользователей (таблица wp_users), мета-данные и посты. Позволяет провести offline-атаку на хэши или получить доступ к админ-панели WordPress.
info.php (webserver02, 10.0.20.60)	Файл с функцией phpinfo(). Раскрывает полную информацию о конфигурации сервера, путях, версиях ПО и переменных окружения.
php.ini (webserver02, 10.0.20.60)	Конфигурационный файл PHP. Размер: 21 байт.
wp-config.php (webserver02, 10.0.20.60)	Файл конфигурации WordPress. (Размер 0 байт, возможно, поврежден или пуст, но сам факт его наличия в корне интересен).
.git/HEAD (webserver01, 10.0.20.61)	Файл заголовка Git-репозитория. Подтверждает возможность восстановления исходного кода веб-приложения DVWA из открытого репозитория.
phpinfo.php (webserver01, 10.0.20.61)	Файл с функцией phpinfo(). Раскрывает конфигурацию сервера DVWA.

php.ini (webserver01, 10.0.20.61)	Конфигурационный файл PHP. Размер: 154 байта.
setup.php (webserver01, 10.0.20.61)	Страница настройки DVWA. Может содержать информацию о дефолтных учетных данных приложения.

Шаг 5.

Краткое описание проведенного анализа.

На этапе анализа открытых источников (Шаг 2) в файле robots.txt веб-сервера 10.0.20.60 были обнаружены учетные данные: логин student и пароль PerfectionPersonified.

На этапе разведки (Шаг 1) было установлено, что на рабочей станции ws01 (10.0.20.11) открыт порт 5985 (WinRM), что позволяет удаленно управлять системой по протоколу WS-Management.

С помощью утилиты evil-winrm было выполнено успешное подключение к машине главного бухгалтера:

evil-winrm -i 10.0.20.11 -u student -p PerfectionPersonified

В результате исследования файловой системы пользователя student в директории C:\Users\student\Documents\Confidential\ был обнаружен критически важный файл ***Пароли админов.txt***, содержащий учетные данные для привилегированных доступов.

В ходе исследования файловой системы рабочей станции главного бухгалтера (ws01, IP 10.0.20.11) в директории C:\Users\student\Desktop\Confidential\ был обнаружен текстовый файл Пароли админов.txt, содержащий учетные данные нескольких администраторов домена, переданные, предположительно, системным администратором для работы с 1С.

- Учетные данные администратора:

Логин	**Пароль**
Admin	n91qwcqw721
FErmanov	01wd972bc61
TRogov	lqg285bv96x
PSarchuk	qfo72hcg754

- Путь к файлу: C:\Users\student\Desktop\Confidential\Пароли админов.txt
- Скриншоты:

```
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\student\Documents> dir C:\Users\student\Desktop


    Каталог: C:\Users\student\Desktop


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
d-----         7/3/2023   7:35 PM                Отчёт за июль 2013 года
d-----         7/3/2023   7:30 PM                Отчёт за октябрь 2077 года


*Evil-WinRM* PS C:\Users\student\Documents> dir C:\Users\student\Documents


    Каталог: C:\Users\student\Documents


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
d-----         7/3/2023  10:11 PM                Confidential


*Evil-WinRM* PS C:\Users\student\Documents> Get-ChildItem -Path C:\Users\student -Recurse -Include *.txt, *.csv, *.xml, *.config -ErrorAction Silent


    Каталог: C:\Users\student\Desktop\Отчёт за июль 2013 года


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
-a----        7/11/2023  11:40 AM            139 7 июля.txt

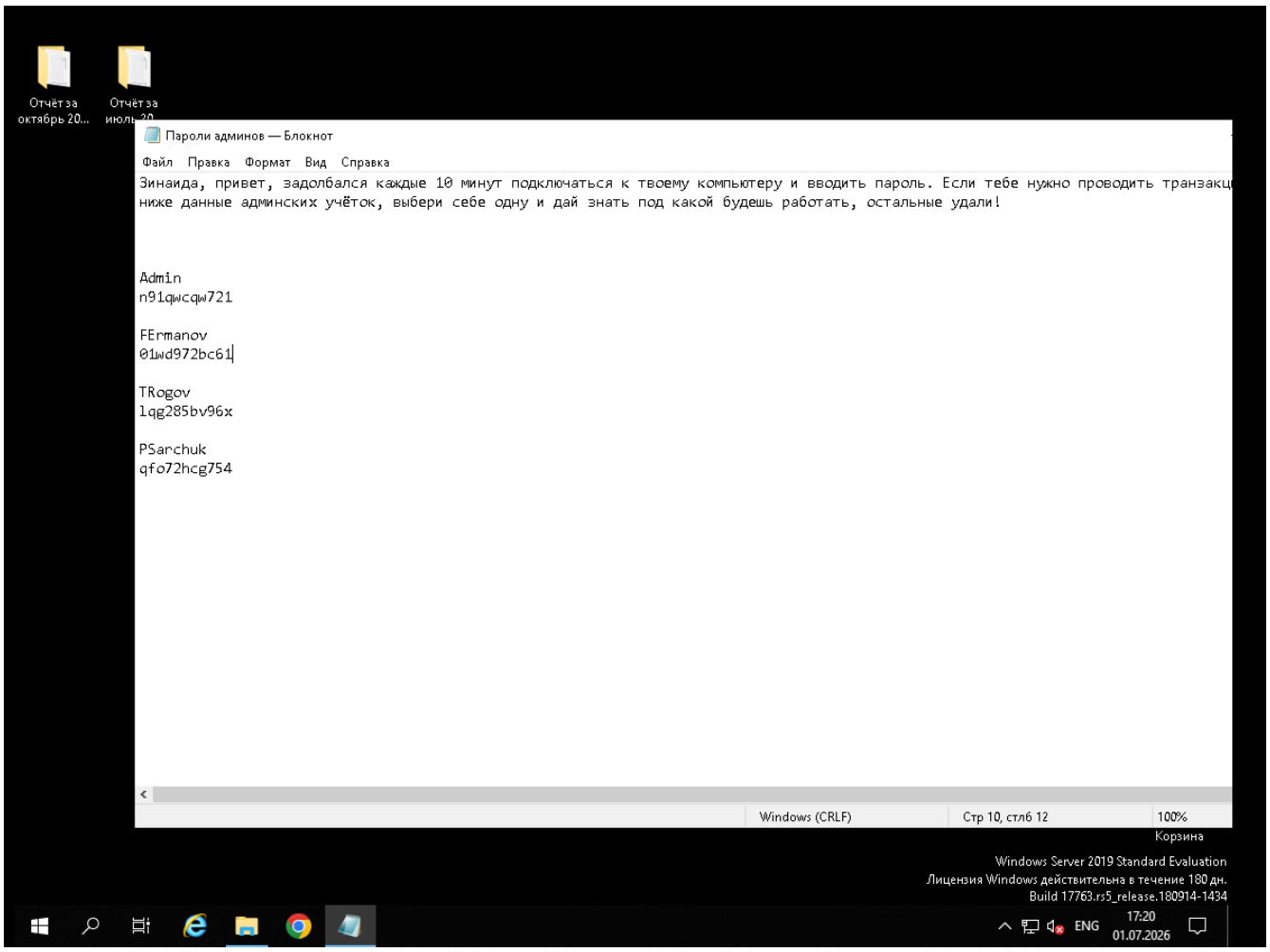

    Каталог: C:\Users\student\Desktop\Отчёт за октябрь 2077 года

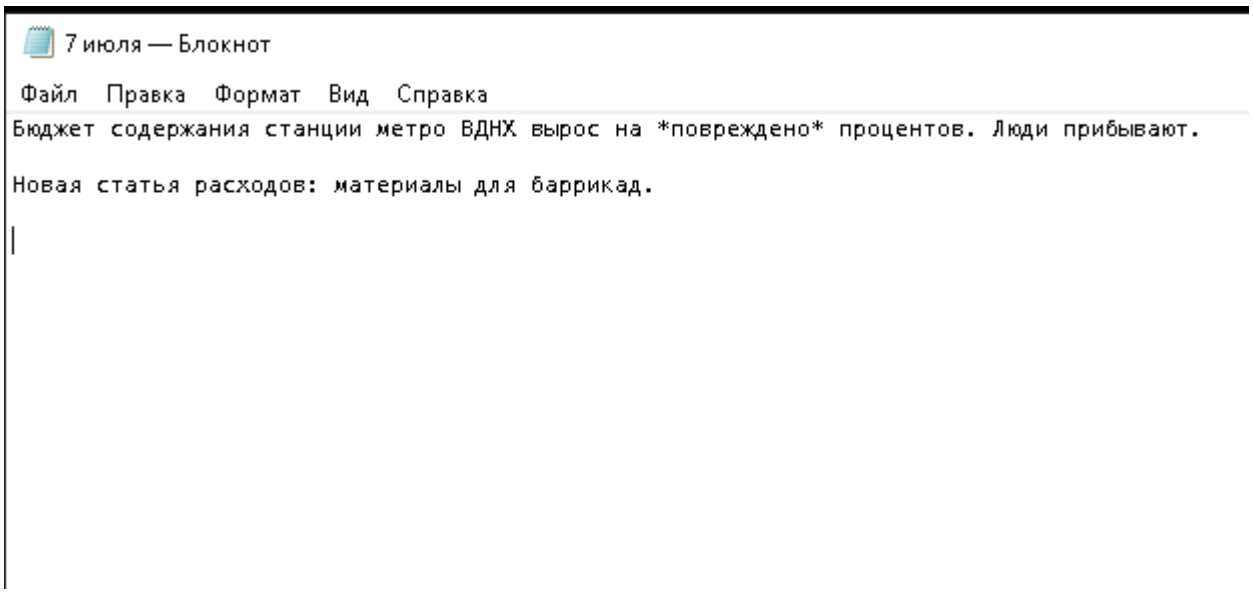

Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
-a----         7/3/2023   7:33 PM            110 23 октября.txt

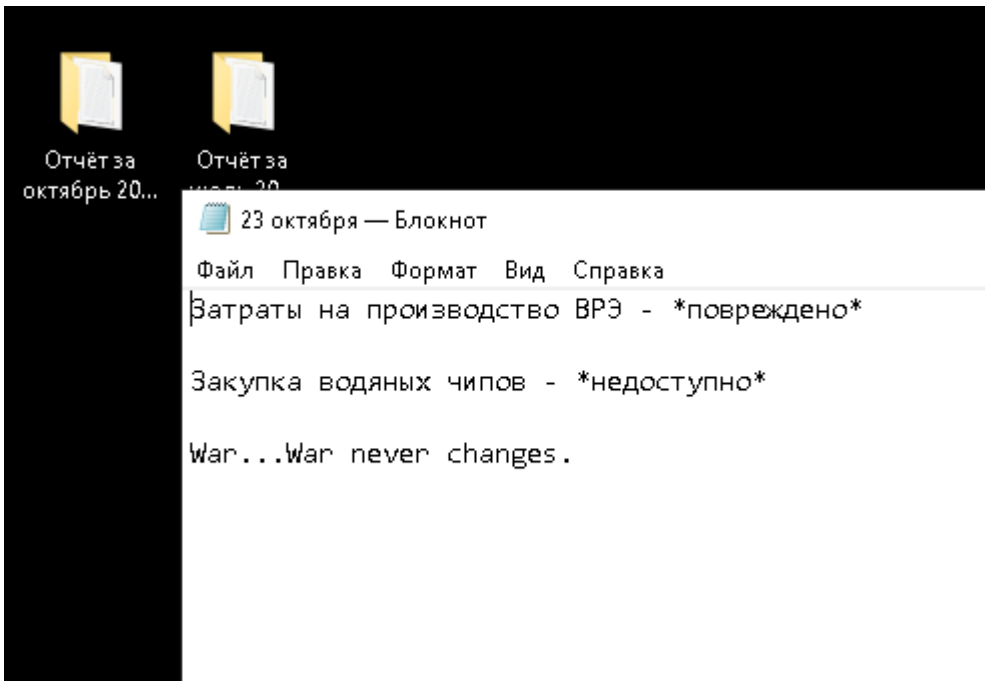

    Каталог: C:\Users\student\Documents\Confidential


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
-a----         7/3/2023  10:13 PM            350 Пароли админов.txt


*Evil-WinRM* PS C:\Users\student\Documents>
```


Отчёт за октябрь 20...
Отчёт за июль 20...
Пароли админов — Блокнот
Файл Правка Формат Вид Справка
Зинаида, привет, задолбался каждые 10 минут подключаться к твоему компьютеру и вводить пароль. Если тебе нужно проводить транзакц
ниже данные админских учёток, выбери себе одну и дай знать под какой будешь работать, остальные удали!
Admin
n91qwcqw721
FErmanov
01wd972bc61
TRogov
lqg285bv96x
PSarchuk
qfo72hcg754
Windows (CRLF)
Стр 10, стлб 12
100%
Корзина
Windows Server 2019 Standard Evaluation
Лицензия Windows действительна в течение 180 дн.
Build 17763.rs5_release.180914-1434
ENG
17:20
01.07.2026

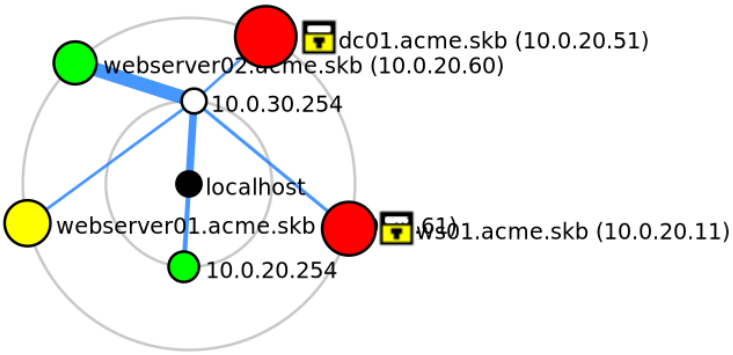

7 июля — Блокнот
Файл Правка Формат Вид Справка
Бюджет содержания станции метро ВДНХ вырос на *повреждено* процентов. Люди прибывают.
Новая статья расходов: материалы для баррикад.


Отчёт за октябрь 20...
Отчёт за
23 октября — Блокнот
Файл Правка Формат Вид Справка
Затраты на производство ВРЭ - *повреждено*
Закупка водяных чипов - *недоступно*
War...War never changes.

Шаг 6.

Задание 1. Граф связей в Zenmap

Скриншоты:



Задание 2.

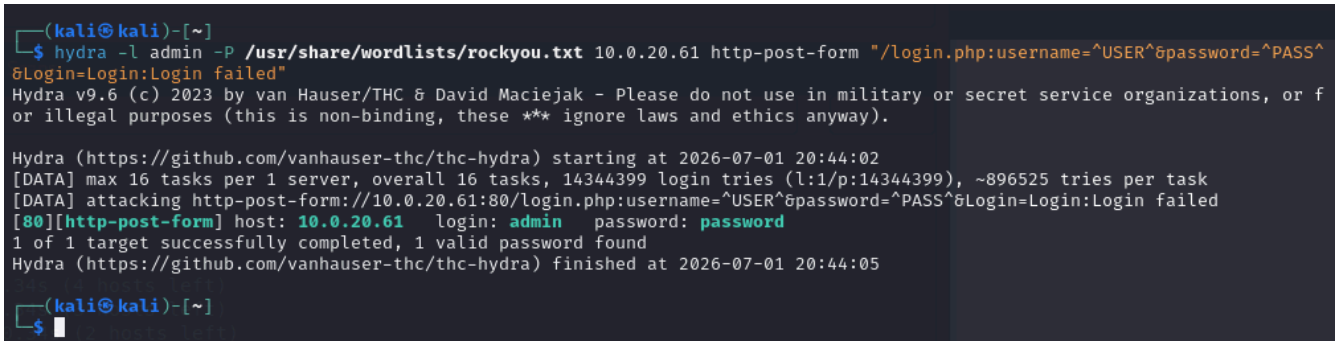
Описание действий:

Подбор пароля к DVWA (Hydra + rockyou)

Полученный результат:

Подобран пароль к форме логина на http://10.0.20.61/login.php.

Скриншоты:



Задание 3. Подбор пароля к RDP бухгалтера (Hydra + rockyou)

Описание действий:

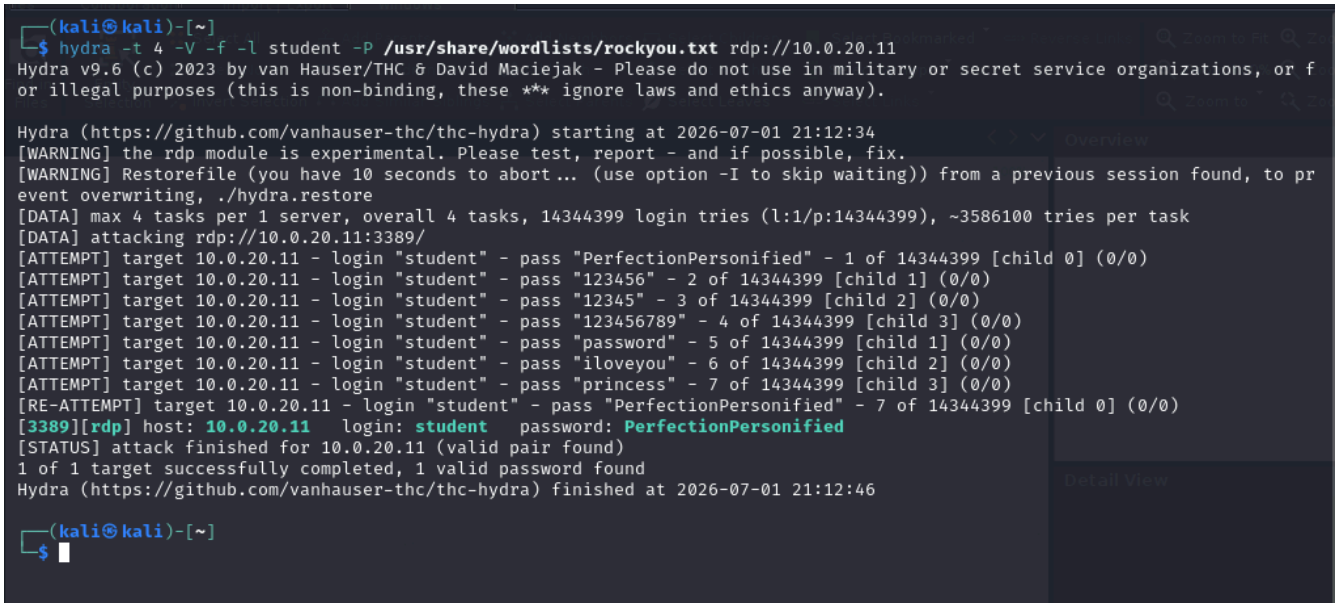
Для подбора пароля к службе RDP на хосте 10.0.20.11 была использована утилита hydra со словарём rockyou.txt.

Полученный результат:

Подобран пароль для пользователя student к службе RDP на 10.0.20.11.

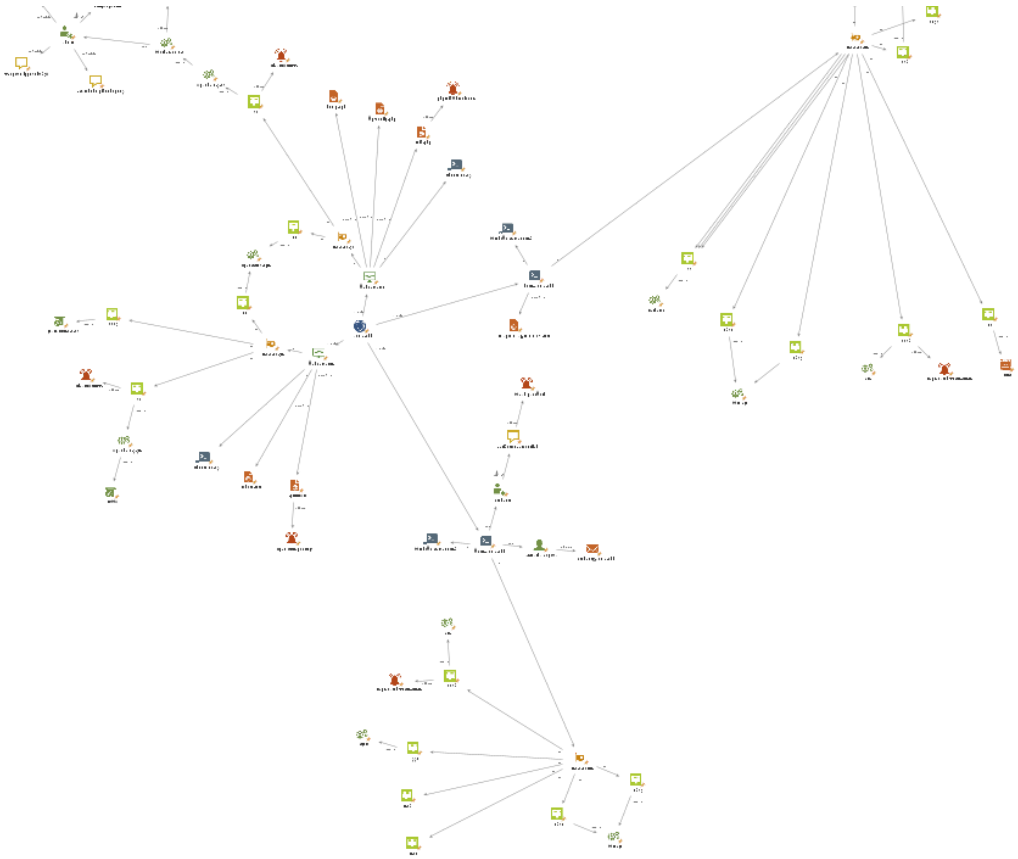
- Логин: student
- Пароль: PerfectionPersonified

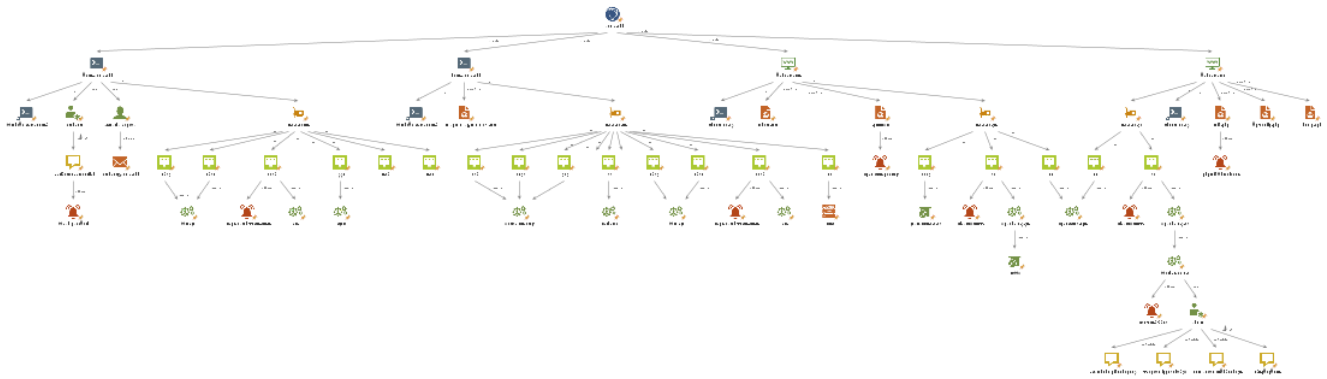
Скриншоты:



Примечание: Для ускорения процесса тестирования в рамках учебного проекта использовался оптимизированный порядок словаря, основанный на предположении о слабых паролях. В реальных условиях рекомендуется использовать более специализированные словари и методы атак.

Задание 4. Граф связей в Maltego





(Подробнее – в приложении отдельным файлом).

Шаг 7.

Рекомендации по повышению уровня безопасности инфраструктуры

Уязвимости высокого уровня угрозы (требуют немедленного устранения):

1. **Уязвимость** в виде хранения учетных данных администраторов в открытом виде имеет критический уровень угрозы, так как привела к полной компрометации домена. Файл "Пароли админов.txt" с учетными записями (Admin, FErmanov, TRogov, PSarchuk) находился в открытом доступе на рабочем столе главного бухгалтера.
   Рекомендация: Немедленно сменить все пароли администраторов домена. Внедрить использование менеджеров паролей (например, KeePass, Bitwarden). Запретить хранение учетных данных в текстовых файлах. Настроить политики DLP для предотвращения утечек.

2. **Уязвимость CVE-2021-43008** (Adminer 1.12.0 - 4.6.2 Information Disclosure) имеет высокий уровень угрозы (CVSS 7.5), так как позволяет атакующему читать произвольные файлы на сервере через подключение к удаленной БД MySQL.
   Рекомендация: Обновить Adminer до версии 4.6.3 или выше. Ограничить доступ к Adminer только с доверенных IP-адресов.

3. **Уязвимость в виде раскрытия информации через phpinfo()** имеет высокий уровень угрозы (CVSS 7.5), так как раскрывает полную конфигурацию сервера, версии ПО, пути и переменные окружения, что значительно облегчает дальнейшую эксплуатацию.
   Рекомендация: Удалить файлы info.php и phpinfo.php с веб-серверов (10.0.20.60 и 10.0.20.61). Запретить использование функции phpinfo() в production-окружении через директиву disable_functions в php.ini.

4. **Уязвимость в виде слабого пароля** пользователя student (PerfectionPersonified), оставленного в файле robots.txt, имеет высокий уровень угрозы, так как позволила получить первоначальный доступ к рабочей станции главного бухгалтера через WinRM.
   Рекомендация: Немедленно сменить пароль пользователя student. Удалить учетные данные из robots.txt. Внедрить политику сложности паролей (минимум 12 символов, регистр, цифры, спецсимволы). Настроить регулярную ротацию паролей.

5. **Уязвимость в виде дампа базы данных** (dump.sql) в открытом доступе на веб-сервере 10.0.20.60 имеет высокий уровень угрозы, так как содержит хэши паролей пользователей WordPress и мета-данные, что позволяет провести offline-атаку.
   Рекомендация: Удалить файл dump.sql из корневой директории веб-сервера. Настроить регулярное резервное копирование БД с хранением бэкапов в защищенном месте. Запретить доступ к файлам с расширением .sql через конфигурацию веб-сервера.

Уязвимости среднего уровня угрозы:

1. **Уязвимость CVE-2019-9978 (WordPress Social Warfare Plugin < 3.5.3 XSS)** имеет средний уровень угрозы (CVSS 6.1), так как позволяет внедрять вредоносный контент на сайт и похищать сессии пользователей.
   Рекомендация: Обновить плагин Social Warfare до версии 3.5.3 или выше. Регулярно обновлять все плагины WordPress.

2. **Уязвимость в виде устаревшей версии CMS WordPress 5.3** имеет средний уровень угрозы, так как содержит множество известных уязвимостей, для которых существуют публичные эксплойты.
   Рекомендация: Обновить WordPress до актуальной стабильной версии. Настроить автоматические обновления безопасности.

3. **Уязвимость в виде открытого Git-репозитория** (.git/HEAD) на веб-сервере 10.0.20.61 имеет средний уровень угрозы, так как позволяет восстановить исходный код приложения DVWA и найти в нем захардкоженные пароли и секреты.
   Рекомендация: Удалить директорию .git из корневой директории веб-сервера. Настроить .gitignore и исключить служебные директории из деплоя. Запретить доступ к скрытым файлам и директориям через конфигурацию Apache.

4. **Уязвимость в виде передачи чувствительной информации в открытом виде (Cleartext HTTP)** имеет средний уровень угрозы, так как позволяет перехватить учетные данные и сессионные cookie с помощью MITM-атаки.
   Рекомендация: Настроить принудительное использование HTTPS (TLS 1.2+) для всех веб-серверов. Настроить редирект с HTTP на HTTPS. Внедрить HSTS (HTTP Strict Transport Security).

5. **Уязвимость в виде использования устаревших протоколов TLS 1.0/1.1** имеет средний уровень угрозы (CVSS 4.3), так как протоколы подвержены известным криптографическим уязвимостям (BEAST, FREAK).
   Рекомендация: Отключить поддержку TLS 1.0 и TLS 1.1 на всех серверах (RDP, WinRM, веб-серверы). Оставить только TLS 1.2 и TLS 1.3.

6. **Уязвимость в виде сертификата, подписанного слабым алгоритмом (SHA-1)** имеет средний уровень угрозы (CVSS 4.0), так как снижает надежность SSL/TLS-защиты.
   Рекомендация: Заменить SSL/TLS сертификаты на сертификаты, подписанные алгоритмом SHA-256 или выше.

7. **Уязвимость в виде отсутствия атрибута HttpOnly у сессионных cookie** имеет средний уровень угрозы, так как позволяет получить доступ к cookie через JavaScript (Session Hijacking).
   Рекомендация: Настроить атрибуты HttpOnly, Secure и SameSite для всех сессионных cookie.

8. **Уязвимость в виде перечисления служб DCE/RPC и MSRPC** имеет средний уровень угрозы, так как позволяет атакующему получить детальную информацию о хосте и потенциальных векторах атаки.
   Рекомендация: Ограничить доступ к портам 135, 139, 445 с помощью межсетевого экрана. Настроить сегментацию сети.

Уязвимости низкого уровня угрозы:

1. **Уязвимость в виде включенных TCP timestamps** имеет низкий уровень угрозы (CVSS 2.6), так как позволяет удаленно вычислить время непрерывной работы хоста (uptime).
   Рекомендация: Отключить TCP timestamps через настройку net.ipv4.tcp_timestamps = 0 в /etc/sysctl.conf (Linux) или netsh int tcp set global timestamps=disabled (Windows).

2. **Уязвимость в виде раскрытия информации через ICMP Timestamp Reply** имеет низкий уровень угрозы (CVSS 2.1), так как теоретически может быть использована для эксплуатации слабых генераторов случайных чисел.
   Рекомендация: Заблокировать ICMP-запросы временной метки на межсетевом экране.

Общие рекомендации по повышению уровня защищенности:

- **Внедрить принцип наименьших привилегий (Least Privilege)**: ограничить права пользователей и администраторов только необходимыми для работы.

- **Настроить многофакторную аутентификацию (MFA)** для всех учетных записей с повышенными привилегиями, особенно для RDP и WinRM.

- **Внедрить систему мониторинга и логирования (SIEM)** для обнаружения подозрительной активности в реальном времени.

- **Проводить регулярные пентесты (не реже одного раза в год)** и сканирования уязвимостей.

- **Настроить сегментацию сети:** изолировать критичные серверы (контроллер домена, веб-серверы) в отдельные VLAN с ограниченным доступом.

- **Внедрить политику регулярного обновления ПО (Patch Management)** для всех систем и приложений.

- **Провести обучение сотрудников по основам информационной безопасности**, особенно по правилам хранения учетных данных и работе с конфиденциальной информацией.

- **Настроить резервное копирование критичных данных** с хранением бэкапов в изолированном и защищенном месте.

Шаг 8.

Выводы

По результатам проведенного тестирования на проникновение инфраструктуры компании ООО "Софтвер Солюшинз" (acme.skb) был выявлен ряд критических уязвимостей, позволяющих злоумышленнику получить полный контроль над корпоративной сетью и конфиденциальными данными.

В ходе исследования, выполненного по сценарию "Серый ящик" (Gray Box), атакующий без каких-либо предварительных учетных данных смог последовательно пройти все этапы Kill Chain: от разведки открытых источников и сканирования инфраструктуры до получения доступа к рабочей станции главного бухгалтера и извлечения учетных данных администраторов домена.

Ключевым вектором атаки стало обнаружение учетных данных (логин student, пароль PerfectionPersonified) в файле robots.txt веб-сервера, что позволило авторизоваться на рабочей станции ws01.acme.skb через протокол WinRM. В дальнейшем в файловой системе бухгалтера был обнаружен файл Пароли админов.txt, содержащий учетные данные четырех администраторов домена в открытом виде.

Общая оценка защищенности инфраструктуры заказчика – **низкая**. Выявленные уязвимости носят системный характер и свидетельствуют о фундаментальных пробелах в процессах информационной безопасности: отсутствии политик хранения учетных данных, слабой конфигурации веб-серверов, использовании устаревшего программного обеспечения и отсутствии сегментации сети.

Наиболее существенные риски информационной безопасности:

1. **Компрометация учетных данных администраторов домена** – критический риск, позволяющий злоумышленнику получить полный контроль над Active Directory, всеми серверами и рабочими станциями компании, а также доступ к конфиденциальной информации и базам данных.

2. **Хранение учетных данных в открытом виде** – как на веб-сервере (файл robots.txt), так и на рабочих станциях (файл Пароли админов.txt), что делает их доступными для любого пользователя с минимальными привилегиями.

3. **Использование устаревшего программного обеспечения** – CMS WordPress 5.3, плагин Social Warfare 3.5.2 и другие компоненты содержат известные уязвимости (CVE-2019-9978, CVE-2021-43008), для которых существуют публичные эксплойты.

4. **Отсутствие сегментации сети** – все серверы и рабочие станции находятся в одной подсети (10.0.20.0/24), что позволяет атакующему беспрепятственно перемещаться между системами после первоначального проникновения.

5. **Слабая криптографическая защита** – использование устаревших протоколов TLS 1.0/1.1 и сертификатов с алгоритмом подписи SHA-1 делает передачу данных уязвимой для перехвата и атак типа "человек посередине" (MITM).

Для минимизации рисков необходимо в кратчайшие сроки реализовать рекомендации, изложенные в Шаге 7 отчета, с приоритетом на устранение уязвимостей высокого уровня угрозы: смену всех скомпрометированных паролей, внедрение многофакторной аутентификации, обновление программного обеспечения и разработку политик информационной безопасности.